

Dual_EC_DRBG (Dual Elliptic Curve Deterministic Random Bit Generator) is an algorithm that was presented as a cryptographically secure pseudorandom number generator (CSPRNG) using methods in elliptic curve cryptography. Despite wide public criticism, including the public identification of the possibility that the National Security Agency put a backdoor into a recommended implementation, it was, for seven years, one of four CSPRNGs standardized in NIST SP 800-90A as originally published circa June 2006, until it was withdrawn in 2014.

Weakness: a potential backdoor

Weaknesses in the cryptographic security of the algorithm were known and publicly criticised well before the algorithm became part of a formal standard endorsed by the ANSI, ISO, and formerly by the National Institute of Standards and Technology (NIST). One of the weaknesses publicly identified was the potential of the algorithm to harbour a cryptographic backdoor advantageous to those who know about it—the United States government's National Security Agency (NSA)—and no one else. In 2013, The New York Times reported that documents in their possession but never released to the public "appear to confirm" that the backdoor was real, and had been deliberately inserted by the NSA as part of its Bullrun decryption program. In December 2013, a Reuters news article alleged that in 2004, before NIST standardized Dual_EC_DRBG, NSA paid RSA Security \$10 million in a secret deal to use Dual_EC_DRBG as the default in the RSA BSAFE cryptography library, which resulted in RSA Security becoming the most important distributor of the insecure algorithm. RSA responded that they "categorically deny" that they had ever knowingly colluded with the NSA to adopt an algorithm that was known to be flawed, but also stated, "We have never kept this relationship [with the NSA] a secret and in fact have openly publicized it."

Sometime before its first known publication in 2004, a possible kleptographic backdoor was discovered with the Dual_EC_DRBG's design, with the design of Dual_EC_DRBG having the unusual property that it was theoretically impossible for anyone but Dual_EC_DRBG's

designers (NSA) to confirm the backdoor's existence. Bruce Schneier concluded shortly after standardization that the "rather obvious" backdoor (along with other deficiencies) would mean that nobody would use Dual_EC_DRBG. The backdoor would allow NSA to decrypt for example SSL/TLS encryption which used Dual_EC_DRBG as a CSPRNG.

Members of the ANSI standard group to which Dual_EC_DRBG was first submitted were aware of the exact mechanism of the potential backdoor and how to disable it, but did not elect to disable or publicize the backdoor. The general cryptographic community was initially not aware of the potential backdoor, until Dan Shumow and Niels Ferguson's publication, or of Certicom's Daniel R. L. Brown and Scott Vanstone's 2005 patent application describing the backdoor mechanism.

In September 2013, The New York Times reported that internal NSA memos leaked by Edward Snowden indicated that the NSA had worked during the standardization process to eventually become the sole editor of the Dual_EC_DRBG standard, and concluded that the Dual_EC_DRBG standard did indeed contain a backdoor for the NSA. In response, NIST stated that "NIST would not deliberately weaken a cryptographic standard", but according to the New York Times story, the NSA had been spending \$250 million per year to insert backdoors in software and hardware as part of the Bullrun program. A Presidential advisory committee subsequently set up to examine NSA's conduct recommended among other things that the US government "fully support and not undermine efforts to create encryption standards".

On April 21, 2014, NIST withdrew Dual_EC_DRBG from its draft guidance on random number generators recommending that "current users of Dual_EC_DRBG transition to one of the three remaining approved algorithms as quickly as possible".

Timeline of Dual_EC_DRBG

Description

Overview

The algorithm uses a single integer s as state. Whenever a new random number is requested, this integer is updated. The k th state is given by

$$s_k$$

$$=$$

$$g$$

$$p$$

$$($$

$$s_k$$

$$-$$

$$1$$

)

$$s_{\{k\}}=g_{\{P\}}(s_{\{k-1\}})$$

The returned random integer r is a function of the state. The k th random number is

r

k

$=$

g

Q

(

s

k

)

$$r_k = g_Q(s_k)$$

The function

g

p

(

x

)

$$g_{\{P\}}(x)$$

depends on the fixed elliptic curve point P.

g

Q

(

x

)

$$g_{\{Q\}}(x)$$

is similar except that it uses the point Q. The points P and Q stay constant for a particular implementation of the algorithm.

Details

The algorithm allows for different constants, variable output length and other customization.

For simplicity, the one described here will use the constants from curve P-256 (one of the 3 sets of constants available) and have fixed output length. The algorithm operates exclusively over a prime finite field

F

p

$$\mathrm{F}_{\mathrm{p}}$$

(

Z

/

p

Z

$$\{\mathrm{Z} / p\mathrm{Z}\}$$

), where p is prime. The state, the seed and the random numbers are all elements of this field.

Field size is

p

=

f

f

f

f

f

f

f

f

00000000

f

f

f

f

f

f

f

f

f

f

f

f

f

f

f

f

b

c

e

6

f

a

a

d

a

7179

e

84

f

3

b

9

c

a

c

2

f

c

632551

16

$$\{$$

$$p=\{\mathtt$$

{ffffffff00000000ffffffffffffbce6faada7179e84f3b9cac2fc632551}}_{16}}

An elliptic curve over

F

p

$$\mathrm{F}_p$$

is given

y

2

=

x

3

-

3

x

+

b

$$\{ \displaystyle y^{\{2\}} = x^{\{3\}} - 3x + b \}$$

where the constant b is

b

=

5

a

c

635

d

8

a

a

3

a

93

e

7

b

3

e

b

b

d

55769886

b

c

651

d

06

b

0

c

c

53

b

0

f

63

b

c

e

3

c

3

e

27

d

2604

b

$$b = \frac{1}{2} \left(\frac{1}{2} + \frac{1}{2} \right) = \frac{1}{2}$$

The points on the curve are

E

(

F

p

)

$$E(\mathrm{F}_{\{p\}})$$

. Two of these points are given as the fixed points P and Q

P

,

Q

∈

E

(

F

p

)

$$P,Q\in E(\mathrm{F}_{\{p\}})$$

Their coordinates are

P

x

=

6

b

17

d

1

f

2

e

12

c

4247

f

8

b

c

e

6

e

5

63

a

440

f

2

77037

d

81

2

d

e

b

33

a

0

f

4

a

13945

d

898

c

296

P

y

=

4

f

e

342

e

2

f

e

1

a

7

f

9

b

8

e

e

7

e

b

4

a

7

c

0

f

9

e

16

2

b

c

e

3357

6

b

315

e

c

e

c

b

b

64068

37

b

f

51

f

5

16

Q

x

=

c

97445

f

4

5

c

d

e

f

9

f

0

d

3

e

05

e

1

e

585

f

c

297

235

b

82

b

5

b

e

8

f

f

3

e

f

c

a

67

c

598

52018192

Q

y

=

b

28

e

f

557

b

a

31

d

f

c

b

d

d

21

a

c

46

e

2

a

91

e

3

c

304

f

44

c

b

87058

a

d

a

2

c

b

81515

1

e

610046

$$\begin{aligned} P_{x\&=\{\mathtt{6b17d1f2\ e12c4247\ f8bce6e5\ 63a440f2\ 77037d81\ 2deb33a0\ f4a13945\ d898c296}}_{\sim 16}} P_{y\&=\{\mathtt{4fe342e2\ fe1a7f9b\ 8ee7eb4a\ 7c0f9e16\ 2bce3357\ 6b315ece\ cbb64068\ 37bf51f5}}_{\sim 16}} Q_{x\&=\{\mathtt{c97445f4\ 5cdef9f0\ d3e05e1e\ 585fc297\ 235b82b5\ be8ff3ef\ ca67c598\ 52018192}}_{\sim 16}} Q_{y\&=\{\mathtt{b28ef557\ ba31dfcb\ dd21ac46\ e2a91e3c\ 304f44cb\ 87058ada\ 2cb81515\ 1e610046}}_{\sim 16}} \end{aligned}$$

A function to extract the x-coordinate is used. It "converts" from elliptic curve points to elements of the field.

X
(
x
,
y
)
=
x

$$X(x,y)=x$$

Output integers are truncated before being output

t

(

x

)

=

x

mod

p

2

16

$$t(x)=x \pmod{\frac{p}{2^{16}}}$$

The functions

g

p

$$g_{\{P\}}$$

and

g

Q

$$g_{Q}$$

. These functions raise the fixed points to a power. "Raising to a power" in this context, means using the special operation defined for points on elliptic curves.

g

P

(

x

)

=

X

(

P

x

)

$$g_{\{P\}}(x)=X(P^{\{x\}})$$

g

Q

(

x

)

=

t

(

X

(

Q

x

)

)

$$g_Q(x)=t(X(Q^x))$$

The generator is seeded with an element from

F

p

$$\mathrm{F}_p$$

s

1

=

g

P

(

seed

)

$$s_1=g_P(\text{seed})$$

The kth state and random number

s

k

=

g

P

(

s

k

-

1

)

$$s_k=g_P(s_{k-1})$$

r

k

=

g

Q

(

s

k

)

$${\displaystyle r_{\{k\}}=g_{\{Q\}}(s_{\{k\}})}$$

The random numbers

r

1

,

r

2

,

...

$$r_{\{1\}}, r_{\{2\}}, \ldots$$

Security

The stated purpose of including the Dual_EC_DRBG in NIST SP 800-90A is that its security is based on computational hardness assumptions from number theory. A mathematical security reduction proof can then prove that as long as the number theoretical problems are hard, the random number generator itself is secure. However, the makers of Dual_EC_DRBG did not publish a security reduction for Dual_EC_DRBG, and it was shown soon after the NIST draft was published that Dual_EC_DRBG was indeed not secure, because it output too many bits per round. The output of too many bits (along with carefully chosen elliptic curve points P and Q) is what makes the NSA backdoor possible, because it enables the attacker to revert the truncation by brute force guessing. The output of too many bits was not corrected in the final

published standard, leaving Dual_EC_DRBG both insecure and backdoored.

In many other standards, constants that are meant to be arbitrary are chosen by the nothing up my sleeve number principle, where they are derived from π or similar mathematical constants in a way that leaves little room for adjustment. However, Dual_EC_DRBG did not specify how the default P and Q constants were chosen, possibly because they were constructed by NSA to be backdoored. Because the standard committee were aware of the potential for a backdoor, a way for an implementer to choose their own secure P and Q was included. But the exact formulation in the standard was written such that use of the alleged backdoored P and Q was required for FIPS 140-2 validation, so the OpenSSL project chose to implement the backdoored P and Q , even though they were aware of the potential backdoor and would have preferred generating their own secure P and Q . New York Times would later write that NSA had worked during the standardization process to eventually become the sole editor of the standard.

A security proof was later published for Dual_EC_DRBG by Daniel R.L. Brown and Kristian Gjøsteen, showing that the generated elliptic curve points would be indistinguishable from uniformly random elliptic curve points, and that if fewer bits were output in the final output truncation, and if the two elliptic curve points P and Q were independent, then Dual_EC_DRBG is secure. The proof relied on the assumption that three problems were hard: the decisional Diffie–Hellman assumption (which is generally accepted to be hard), and two newer less-known problems which are not generally accepted to be hard: the truncated point problem, and the x -logarithm problem. Dual_EC_DRBG was quite slow compared to many alternative CSPRNGs (which don't have security reductions), but Daniel R.L. Brown argues that the security reduction makes the slow Dual_EC_DRBG a valid alternative (assuming implementors disable the obvious backdoor). Note that Daniel R.L. Brown works for Certicom, the main owner of elliptic curve cryptography patents, so there may be a conflict of interest in promoting an EC CSPRNG.

The alleged NSA backdoor would allow the attacker to determine the internal state of the random number generator from looking at the output from a single round (32 bytes); all future output of the random number generator can then easily be calculated, until the CSPRNG is reseeded with an external source of randomness. This makes for example SSL/TLS vulnerable, since the setup of a TLS connection includes the sending of a randomly generated cryptographic nonce in the clear. NSA's alleged backdoor would depend on their knowing of the single e such that

e

Q

$=$

P

$$eQ = P$$

. This is a hard problem if P and Q are set ahead of time, but it's easier if P and Q are chosen. e is a secret key presumably known only by NSA, and the alleged backdoor is a kleptographic asymmetric hidden backdoor. Matthew Green's blog post [The Many Flaws of Dual_EC_DRBG](#) has a simplified explanation of how the alleged NSA backdoor works by employing the discrete-log kleptogram introduced in Crypto 1997.

Standardization and implementations

NSA first introduced Dual_EC_DRBG in the ANSI X9.82 DRBG in the early 2000s, including the

same parameters which created the alleged backdoor, and Dual_EC_DRBG was published in a draft ANSI standard. Dual_EC_DRBG also exists in the ISO 18031 standard.

According to John Kelsey (who together with Elaine Barker was listed as author of NIST SP 800-90A), the possibility of the backdoor by carefully chosen P and Q was brought up at an ANSI X9F1 Tool Standards and Guidelines Group meeting. When Kelsey asked Don Johnson of Cygnacom about the origin of Q, Johnson answered in a 27 October 2004 email to Kelsey that NSA had prohibited the public discussion of generation of an alternative Q to the NSA-supplied one.

At least two members of the Members of the ANSI X9F1 Tool Standards and Guidelines Group which wrote ANSI X9.82, Daniel R. L. Brown and Scott Vanstone from Certicom, were aware of the exact circumstances and mechanism in which a backdoor could occur, since they filed a patent application in January 2005 on exactly how to insert or prevent the backdoor in DUAL_EC_DRBG. The working of the "trap door" mentioned in the patent is identical to the one later confirmed in Dual_EC_DRBG. Writing about the patent in 2014, commentator Matthew Green describes the patent as a "passive-aggressive" way of spiting NSA by publicizing the backdoor, while still criticizing everybody on the committee for not actually disabling the backdoor they obviously were aware of. Brown and Vanstone's patent list two necessary conditions for the backdoor to exist:

1) Chosen Q

An elliptic curve random number generator avoids escrow keys by choosing a point Q on the elliptic curve as verifiably random. Intentional use of escrow keys can provide for back up functionality. The relationship between P and Q is used as an escrow key and stored by for a security domain. The administrator logs the output of the generator to reconstruct the random number with the escrow key.

2) Small output truncation

[0041] Another alternative method for preventing a key escrow attack on the output of an ECRNG, shown in Figures 3 and 4 is to add a truncation function to ECRNG to truncate the ECRNG output to approximately half the length of a compressed elliptic curve point. Preferably, this operation is done in addition to the preferred method of Figure 1 and 2, however, it will be appreciated that it may be performed as a primary measure for preventing a key escrow attack. The benefit of truncation is that the list of R values associated with a single ECRNG output r is typically infeasible to search. For example, for a 160-bit elliptic curve group, the number of potential points R in the list is about 280, and searching the list would be about as hard as solving the discrete logarithm problem. The cost of this method is that the ECRNG is made half as efficient, because the output length is effectively halved.

According to John Kelsey, the option in the standard to choose a verifiably random Q was added as an option in response to the suspected backdoor, though in such a way that FIPS 140-2 validation could only be attained by using the possibly backdoored Q. Steve Marquess (who helped implement NIST SP 800-90A for OpenSSL) speculated that this requirement to use the potentially backdoored points could be evidence of NIST complicity. It is not clear why the standard did not specify the default Q in the standard as a verifiably generated number, or why the standard did not use greater truncation, which Brown's patent said could be used as the "primary measure for preventing a key escrow attack". The small truncation was unusual compared to previous EC PRGs, which according to Matthew Green had only output 1/2 to 2/3 of the bits in the output function. The low truncation was in 2006 shown by Gjøsteen to make the RNG predictable and therefore unusable as a CSPRNG, even if Q had not been chosen to contain a backdoor. The standard says that implementations "should" use the small max_outlen provided, but gives the option of outputting a multiple of 8 fewer bits. Appendix C of the standard gives a loose argument that outputting fewer bits will make the output less uniformly distributed. Brown's 2006 security proof relies on outlen being

much smaller the default max_outlen value in the standard.

The ANSI X9F1 Tool Standards and Guidelines Group which discussed the backdoor also included three employees from the prominent security company RSA Security. In 2004, RSA Security made an implementation of Dual_EC_DRBG which contained the NSA backdoor the default CSPRNG in their RSA BSAFE as a result of a secret \$10 million deal with NSA. In 2013, after the New York Times reported that Dual_EC_DRBG contained a backdoor by the NSA, RSA Security said they had not been aware of any backdoor when they made the deal with NSA, and told their customers to switch CSPRNG. In the 2014 RSA Conference keynote, RSA Security Executive Chairman Art Coviello explained that RSA had seen declining revenue from encryption, and had decided to stop being "drivers" of independent encryption research, but to instead to "put their trust behind" the standards and guidance from standards organizations such as NIST.

A draft of NIST SP 800-90A including the Dual_EC_DRBG was published in December 2005. The final NIST SP 800-90A including Dual_EC_DRBG was published in June 2006. Documents leaked by Snowden have been interpreted as suggesting that the NSA backdoored Dual_EC_DRBG, with those making the allegation citing the NSA's work during the standardization process to eventually become the sole editor of the standard. The early usage of Dual_EC_DRBG by RSA Security (for which NSA was later reported to have secretly paid \$10 million) was cited by the NSA as an argument for Dual_EC_DRBG's acceptance into the NIST SP 800-90A standard. RSA Security subsequently cited Dual_EC_DRBG's acceptance into the NIST standard as a reason they used Dual_EC_DRBG.

Daniel R. L. Brown's March 2006 paper on the security reduction of Dual_EC_DRBG mentions the need for more output truncation and a randomly chosen Q, but mostly in passing, and does not mention his conclusions from his patent that these two defects in Dual_EC_DRBG together can be used as a backdoor. Brown writes in the conclusion: "Therefore, the ECRNG should be a serious consideration, and its high efficiency makes it suitable even for

constrained environments." Note that others have criticised Dual_EC_DRBG as being extremely slow, with Bruce Schneier concluding "It's too slow for anyone to willingly use it", and Matthew Green saying Dual_EC_DRBG is "Up to a thousand times slower" than the alternatives. The potential for a backdoor in Dual_EC_DRBG was not widely publicised outside of internal standard group meetings. It was only after Dan Shumow and Niels Ferguson's 2007 presentation that the potential for a backdoor became widely known. Shumow and Ferguson had been tasked with implementing Dual_EC_DRBG for Microsoft, and at least Ferguson had discussed the possible backdoor in a 2005 X9 meeting. Bruce Schneier wrote in a 2007 Wired article that the Dual_EC_DRBG's flaws were so obvious that nobody would use Dual_EC_DRBG: "It makes no sense as a trap door: It's public, and rather obvious. It makes no sense from an engineering perspective: It's too slow for anyone to willingly use it." Schneier was apparently unaware that RSA Security had used Dual_EC_DRBG as the default in BSAFE since 2004.

OpenSSL implemented all of NIST SP 800-90A including Dual_EC_DRBG at the request of a client. The OpenSSL developers were aware of the potential backdoor because of Shumow and Ferguson's presentation, and wanted to use the method included in the standard to choose a guaranteed non-backdoored P and Q, but were told that to get FIPS 140-2 validation they would have to use the default P and Q. OpenSSL chose to implement Dual_EC_DRBG despite its dubious reputation for completeness, noting that OpenSSL tried to be complete and implements many other insecure algorithms. OpenSSL did not use Dual_EC_DRBG as the default CSPRNG, and it was discovered in 2013 that a bug made the OpenSSL implementation of Dual_EC_DRBG non-functioning, meaning that no one could have been using it.

Bruce Schneier reported in December 2007 that Microsoft added Dual_EC_DRBG support to Windows Vista, though not enabled by default, and Schneier warned against the known potential backdoor. Windows 10 and later will silently replace calls to Dual_EC_DRBG with calls to CTR_DRBG based on AES.

On September 9, 2013, following the Snowden leak, and the New York Times report on the

backdoor in Dual_EC_DRBG, the National Institute of Standards and Technology (NIST) ITL announced that in light of community security concerns, it was reissuing SP 800-90A as draft standard, and re-opening SP800-90B/C for public comment. NIST now "strongly recommends" against the use of Dual_EC_DRBG, as specified in the January 2012 version of SP 800-90A. The discovery of a backdoor in a NIST standard has been a major embarrassment for the NIST.

RSA Security had kept Dual_EC_DRBG as the default CSPRNG in BSAFE even after the wider cryptographic community became aware of the potential backdoor in 2007, but there does not seem to have been a general awareness of BSAFE's usage of Dual_EC_DRBG as a user option in the community. Only after widespread concern about the backdoor was there an effort to find software which used Dual_EC_DRBG, of which BSAFE was by far the most prominent found. After the 2013 revelations, RSA security Chief of Technology Sam Curry provided Ars Technica with a rationale for originally choosing the flawed Dual EC DRBG standard as default over the alternative random number generators. The technical accuracy of the statement was widely criticized by cryptographers, including Matthew Green and Matt Blaze. On December 20, 2013, it was reported by Reuters that RSA had accepted a secret payment of \$10 million from the NSA to set the Dual_EC_DRBG random number generator as the default in two of its encryption products. On December 22, 2013, RSA posted a statement to its corporate blog "categorically" denying a secret deal with the NSA to insert a "known flawed random number generator" into its BSAFE toolkit

Following the New York Times story asserting that Dual_EC_DRBG contained a backdoor, Brown (who had applied for the backdoor patent and published the security reduction) wrote an email to an IETF mailing list defending the Dual_EC_DRBG standard process:

1. Dual_EC_DRBG, as specified in NIST SP 800-90A and ANSI X9.82-3, allows an alternative choice of constants P and Q. As far as I know, the alternatives do not admit a known feasible backdoor. In my view, it is incorrect to imply that Dual_EC_DRBG always has a backdoor,

though I admit a wording to qualify the affected cases may be awkward.

2. Many things are obvious in hindsight. I'm not sure if this was obvious.

[...]

8. All considered, I don't see how the ANSI and NIST standards for Dual_EC_DRBG can be viewed as a subverted standard, per se. But maybe that's just because I'm biased or naive.

Software and hardware which contained the possible backdoor

Implementations which used Dual_EC_DRBG would usually have gotten it via a library. At least RSA Security (BSAFE library), OpenSSL, Microsoft, and Cisco have libraries which included Dual_EC_DRBG, but only BSAFE used it by default. According to the Reuters article which revealed the secret \$10 million deal between RSA Security and NSA, RSA Security's BSAFE was the most important distributor of the algorithm. There was a flaw in OpenSSL's implementation of Dual_EC_DRBG that made it non-working outside test mode, from which OpenSSL's Steve Marquess concludes that nobody used OpenSSL's Dual_EC_DRBG implementation.

A list of products which have had their CSPRNG-implementation FIPS 140-2 validated is available at the NIST. The validated CSPRNGs are listed in the Description/Notes field. Note that even if Dual_EC_DRBG is listed as validated, it may not have been enabled by default. Many implementations come from a renamed copy of a library implementation.

The BlackBerry software is an example of non-default use. It includes support for Dual_EC_DRBG, but not as default. BlackBerry Ltd has however not issued an advisory to any of its customers who may have used it, because they do not consider the probable backdoor a vulnerability. Jeffrey Carr quotes a letter from Blackberry:

The Dual EC DRBG algorithm is only available to third party developers via the Cryptographic

APIs on the [Blackberry] platform. In the case of the Cryptographic API, it is available if a 3rd party developer wished to use the functionality and explicitly designed and developed a system that requested the use of the API.

Bruce Schneier has pointed out that even if not enabled by default, having a backdoored CSPRNG implemented as an option can make it easier for NSA to spy on targets which have a software-controlled command-line switch to select the encryption algorithm, or a "registry" system, like most Microsoft products, such as Windows Vista:

A Trojan is really, really big. You can't say that was a mistake. It's a massive piece of code collecting keystrokes. But changing a bit-one to a bit-two [in the registry to change the default random number generator on the machine] is probably going to be undetected. It is a low conspiracy, highly deniable way of getting a backdoor. So there's a benefit to getting it into the library and into the product.

In December 2013, a proof of concept backdoor was published that uses the leaked internal state to predict subsequent random numbers, an attack viable until the next reseed.

In December 2015, Juniper Networks announced that some revisions of their ScreenOS firmware used Dual_EC_DRBG with the suspect P and Q points, creating a backdoor in their firewall. Originally it was supposed to use a Q point chosen by Juniper which may or may not have been generated in provably safe way. Dual_EC_DRBG was then used to seed ANSI X9.17 PRNG. This would have obfuscated the Dual_EC_DRBG output thus killing the backdoor. However, a "bug" in the code exposed the raw output of the Dual_EC_DRBG, hence compromising the security of the system. This backdoor was then backdoored itself by an unknown party which changed the Q point and some test vectors. Allegations that the NSA had persistent backdoor access through Juniper firewalls had already been published in 2013 by Der Spiegel. The kleptographic backdoor is an example of NSA's NOBUS policy, of having

security holes that only they can exploit.

See also

Random number generator attack

Crypto AG – a Swiss company specialising in communications and information security, who are widely believed to have allowed western security agencies (including NSA) to insert backdoors in their cryptography machines

References

External links

NIST SP 800-90A – Recommendation for Random Number Generation Using Deterministic Random Bit Generators

Dual EC DRBG – Collection of Dual_EC_DRBG information, by Daniel J. Bernstein, Tanja Lange, and Ruben Niederhagen.

On the Practical Exploitability of Dual EC in TLS Implementations – Key research paper by Stephen Checkoway et al.

The prevalence of kleptographic attacks on discrete-log based cryptosystems – Adam L. Young, Moti Yung (1997)

United States Patent Application Publication US 2007189527, Brown, Daniel R. L. & Vanstone, Scott A., "Elliptic curve random number generation", assigned to Certicom Corp. on the Dual_EC_DRBG backdoor, and ways to negate the backdoor.

Comments on Dual-EC-DRBG/NIST SP 800-90, Draft December 2005 Kristian Gjølsteen's March 2006 paper concluding that Dual_EC_DRBG is predictable, and therefore insecure.

A Security Analysis of the NIST SP 800-90 Elliptic Curve Random Number Generator Daniel R. L. Brown and Kristian Gjølsteen's 2007 security analysis of Dual_EC_DRBG. Though at least Brown was aware of the backdoor (from his 2005 patent), the backdoor is not explicitly mentioned.

Use of non-backdoored constants and a greater output bit truncation than Dual_EC_DRBG specifies are assumed.

On the Possibility of a Back Door in the NIST SP800-90 Dual Ec Prng Dan Shumow and Niels Ferguson's presentation, which made the potential backdoor widely known.

The Many Flaws of Dual_EC_DRBG – Matthew Green's simplified explanation of how and why the backdoor works.

A few more notes on NSA random number generators – Matthew Green

Sorry, RSA, I'm just not buying it – Summary and timeline of Dual_EC_DRBG and public knowledge.

[Cfrg] Dual_EC_DRBG ... [was RE: Requesting removal of CFRG co-chair] A December 2013 email by Daniel R. L. Brown defending Dual_EC_DRBG and the standard process.

DUELING OVER DUAL_EC_DRBG: THE CONSEQUENCES OF CORRUPTING A CRYPTOGRAPHIC STANDARDIZATION PROCESS Kostsyuk and Landau article about international cryptographic community's largely continued trust in NIST despite the Dual EC DRBG.